

Break-Glass User & Temporary Fallback Access PRD

Feature Title	Break-Glass User & Temporary Fallback Access
Product Owner	@Pihoo Verma
Tech Owner	@Prerit Sharma @Pratyush Bhardwaj @Ronak Parmaar @Naveen Kumar
Design Owner	@Pratik Raj
IDG Owner	@urooj.mirza
Security	@Saishiva K

Problem Alignment

Problem Statement

"I am an IT Administrator or an external consultant for a large enterprise. Currently, my access to the Whatfix Dashboard is 100% dependent on the Identity Provider (IdP). If the IdP is down, the SSO certificate expires, or a SCIM sync error deprovisions my account, I am locked out of Whatfix with no way to fix the configuration."

Key Pain Points:

- **Single Point of Failure:** Total dependency on SSO means an IdP outage equals a Whatfix outage for admins.
- **SCIM Vulnerability:** Configuration errors in SCIM (like the "72-hour grace period" deactivating the wrong users) can leave an ENT with zero active admins.
- **External Access Friction:** Adding temporary contractors/CSMs to a corporate IdP for short-term projects is a security and administrative burden.
 - Customers-
 - NYC: They wished to have a non-human account (a distribution list of sorts) to be able to log into the Whatfix Dashboard for common use

Target Audience

- **Primary:** Enterprise IT Administrators (Break-Glass use case).

- **Secondary:** External Consultants, Partners, and Whatfix CSMs (Temporary Access use case).

Outcome Summary

- **Business Continuity:** Ensure that at max 5 admins can always access the dashboard via Email OTP fallback to resolve SSO/SCIM issues.
 - **Secure JIT Access:** Provide a mechanism for "Just-in-Time" temporary access that expires automatically.
 - **Reliability:** Decouple emergency administrative access from IdP availability.
-

Solution Alignment

Solution Summary

We will introduce a Fallback Authentication layer. For SSO-enabled ENTs, a neutral entry point on the login screen will allow "Break-Glass" (BGU) and "Temporary" users to bypass the SSO redirect. BGUs and Temporary users will use a local password. Temporary users will have a hard-coded expiration date and receive automated notifications.

Scope of the Solution

- **BGU (Emergency):** Max 5 accounts per ENT. Only available if SSO is enabled.
 - **Temporary Access:** Invitation-based. Admin sets an expiry date (Max 90 days).
 - **Lifecycle Notifications:** Automated emails to Temp users at T-7, T-2, and T-1 days before expiry.
 - **SCIM Protection:** BGUs are exempt from SCIM sync/reconciliation logic.
 - **Auto-Termination:** Immediate session kill upon expiry for temporary users.
-

Solution Specs

1. UI and Behaviour Logic: The Login Entry Point

The entry point must be subtle to prioritise SSO for 99% of users but discoverable for the 1% who need it.

Scenario A: ENT has SSO ENABLED

The entry point is a neutral link that serves both Emergency Admins and Temporary Guests.

1. **Touchpoint:** A link below the SSO button: **"Sign in with password"**.
2. **The Logic:** This leads to a standard **Email** and **Password** screen.

3. **Self-Service:** The existing **"Forgot Password?"** link will be available here, allowing BGU and Temp users to trigger a password reset email.
4. **Validation:** If a Standard (SSO-required) user enters their email, the system displays: *"This account requires SSO. Please return to the main login."*

Scenario B: ENT has SSO DISABLED

1. **Primary UI:** Default login screen showing `Email` and `Password` fields immediately.
2. **The Touchpoint:** Not visible/Hidden.
3. **Access:** Temporary users simply enter their credentials here. BGU logic is inactive as there is no "Glass to Break" (passwords already work).

2. Break-Glass User (BGU) Setup UI

Located in **Settings > Setup > Authentication > Break-Glass Access**.

- **Prerequisite Setup:** The BGU configuration must be completed **before** SCIM is enabled.
- **Configuration:** Admin selects up to **5 existing Admins** as "Emergency Users."
- **Security Alert:** Whenever a BGU logs in via the "Sign in with Password" route, an **immediate email notification is sent to all Admins** in that ENT to ensure the login is authorised.
- **SCIM Immunity:** BGU users are flagged `is_scim_managed: false`. If SCIM disables them, they can still use the fallback door to gain a temporary active session to fix settings.

3. Temporary User Invite & Onboarding Flow

- Located in **User Management > Invite Temporary User**.

A. The Invitation (Admin Side)

Admin fills a modal with:

1. **Email ID.**
2. **Role Selection** (Translator, Editor, etc. — excluding Admin).
3. **Expiry Date:** Custom Date Picker (Max 90 days); Prefill it to 90 days.

B. Invitation Handling (New vs. Existing Users)

The system checks if the invited email already exists in the Whatfix ecosystem:

- **Case 1: User is NEW to Whatfix:** User receives an email with a "Set Password" link. They must set a password before being redirected to the ENT homepage.
- **Case 2: User ALREADY has a Whatfix Account/Password:** User receives an invitation email with an **"Accept Invite"** button. Clicking this skips the password setup, logs them in using their existing credentials, and redirects them to the ENT homepage.

- **Subsequent Logins:** For future sessions, they use the "Sign in with password" link on the login page if the ENT has SSO enabled or they use the default login page with email and password if ENT doesn't have SSO.

C. Onboarding & Notifications

- **Signup:** New users set password (email is read-only) → **Auto-login and redirect to ENT Homepage.**
- **Notifications:** Automated reminders sent to user at **T-7, T-2, and T-1 days** before expiry. To prevent a sudden loss of access, the system sends reminders to the Temp user via email and dashboard notification:
 - **T-7 Days:** "Your access to [ENT Name] expires in 7 days."
 - **T-2 Days:** "Reminder: Your access expires in 48 hours."
 - **T-1 Day:** "Final Notice: Your access expires in 24 hours."

D. Deactivation & Post-Expiry

- **Automatic Deactivation:** At 00:00 of the expiry date, the status changes to **Deactivated** and sessions are killed.
- **Admin Recovery:** Admins can **"Re-invite"** (reactivates profile and sets new expiry) or **"Delete"** (removes profile/reassigns content).
- **Conversion:** Admins can change a Temp User to a **Permanent User** via the Teammates page UI.

2.4 Teammates Page Management

The Teammates page will distinguish between 4 user types:

User Type	Status	UI Actions Available
Active User	Permanent/Active	Disable, Edit Role
Disabled User	Permanent/Inactive	Activate, Delete
Temp User	Active Time-bound	Make Permanent, Edit Expiry (extend for another 90 days max), Delete
Disabled Temp User	Expired	Re-invite , Delete

Key Lifecycle Flows:

1. **Make Permanent:** Admin can toggle a "Temp User" to "Permanent." This clears the expiry date and stops all T-minus notifications.
 2. **Re-invite:** Admin can click "Re-invite" on an expired user to set a new expiry (active Temp) or make them Permanent. This sends a new invitation to activate the profile.
-

3. Error and Success Scenarios

Configuration (Admin Side)

Scenario	Notification Type	Message Text
Adding 1st-5th BGU	Success	"Success: [Email] has been added as a Break-Glass User."
Adding 6th BGU	Error	"Limit Reached: You can only have a maximum of 5 Break-Glass accounts."
Inviting Temp User	Success	"Invitation sent: [Email] will have access until [Expiry Date]."
Invalid Email Format	Error	"Error: Please enter a valid email address."

Login & Access (User Side)

Scenario	Notification Type	Message Text
BGU Login Alert	Admin Email	"Emergency Login Detected: [Email] has accessed the dashboard via fallback login."
Temp User Expired	Error	"Access Expired: Your temporary account reached its end date."

		Please contact your administrator."
Standard User on Fallback	Error	"SSO Required: Please use your company's main login button."
Invalid Credentials	Error	"Incorrect email or password. Please try again."

4. User Stories and Acceptance Criteria

ID	User Story	Acceptance Criteria
US.1	BGU Config	BGU settings are only visible/configurable to Admins if SSO is enabled for the ENT.
US.2	SCIM Immunity	BGU and temp user accounts are never moved to "Disabled Users" by SCIM sync, even if missing from the IdP payload.
US.3	Temp Signup	Clicking the invite link allows the user to set a password with their email pre-filled as read-only.
US.4	Fallback Entry	On SSO ENTs, "Sign in with password" link successfully routes BGUs and Temp Users to local Password fields.
US.5	Hard Expiry	At the exact expiry timestamp, the Temp User's active session is killed. Any refresh/API call must return a 401.
US.6	Type Conversion	Admin can change a Temp User to "Permanent" in the UI, clearing the

		expiry date and stopping notifications.
US.7	Standard Login	For non-SSO ENTs, Temp Users can log in directly on the main login screen using their email/password.
US.8	Re-invite Flow	Admin can re-invite a "Disabled Temp User," triggering a new invite link and restoring the profile upon completion.

5. Analytics to be Tracked

Event Name	Purpose	Parameters
temp_user_invite_d	Tracks usage of the invitation feature.	admin_id , role , duration_selected
temp_user_signup_complete	Tracks when a guest successfully sets their password.	user_id , ent_id
bgu_login_successes	Tracks emergency usage.	user_id , ent_id , attempt_count
temp_access_expired	Tracks automated offboarding.	user_id , ent_id
fallback_unauthorized_attempt	Tracks standard users trying to use the backdoor.	email_domain , ip_address
temp_expiry_notification_sent	Tracks T-7, T-2, T-1 email triggers.	user_id , days_remaining
user_type_conversion	Tracks Temp → Permanent transitions.	user_id , admin_id

Reference from other applications

